

Hydroqualisense Security Overview

A simple guide for your team

Prepared: 2026-09-15

This client handoff version is qualified until the exact release, database, and authenticated synthetic-QA checks are recorded for the deployment being handed over.

1. Security at a glance

Hydroqualisense helps your team manage projects, money, documents, payroll, and communications in one operational workspace.

The security model is built around a few clear boundaries:

- your deployment is for one client company;
- each person signs in with their own account;
- access follows the work that person needs to do;
- important access changes and business history remain reviewable;
- private credentials and provider keys are handled by the server, not ordinary browser users;
- QA uses synthetic data so normal troubleshooting does not require browsing confidential production records.

Your company controls its users, access decisions, connected provider accounts, and production account custody.

2. Who can access what

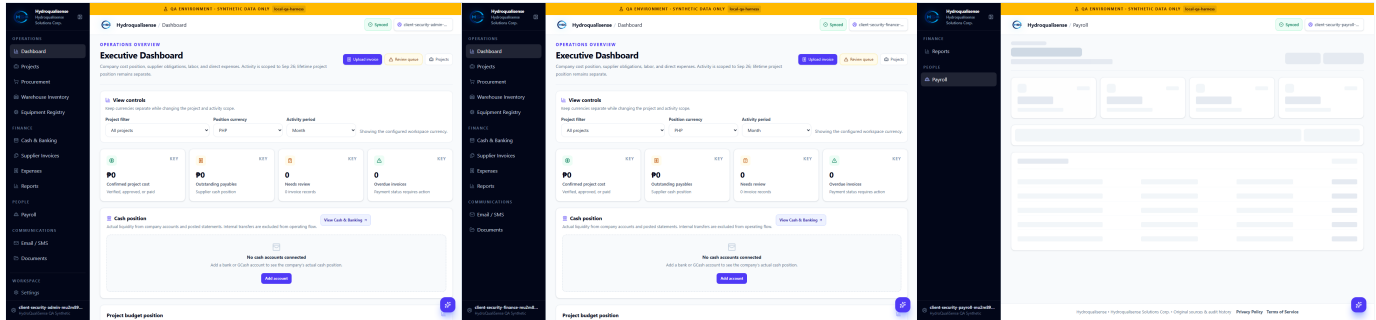
The four ready-to-use roles are protected starter roles. They are useful defaults, not the only roles your company can use.

Starter role	What it is for	What it does not normally include
Company Admin	Company settings, access administration, and the full permitted company workspace	No access to another client's deployment
Finance	Finance and related operational work such as invoices, expenses, cash, procurement, inventory, and financial reports	Payroll detail, workforce administration, and company access administration
Payroll	Payroll, workforce, payroll processing, and payroll reports	General finance, invoices, cash, projects, or company administration
Viewer	Read-only permitted company information	Ordinary editing, approval, settings, or member administration

An authorized Company Admin can create a company-specific role such as Project Manager, Warehouse Staff, or Procurement Reviewer and select only the operational areas that role needs. The role name is for people; the access behind it decides what the person can see and do. Protected company and platform administration stays outside ordinary role customization.

3. Real role examples

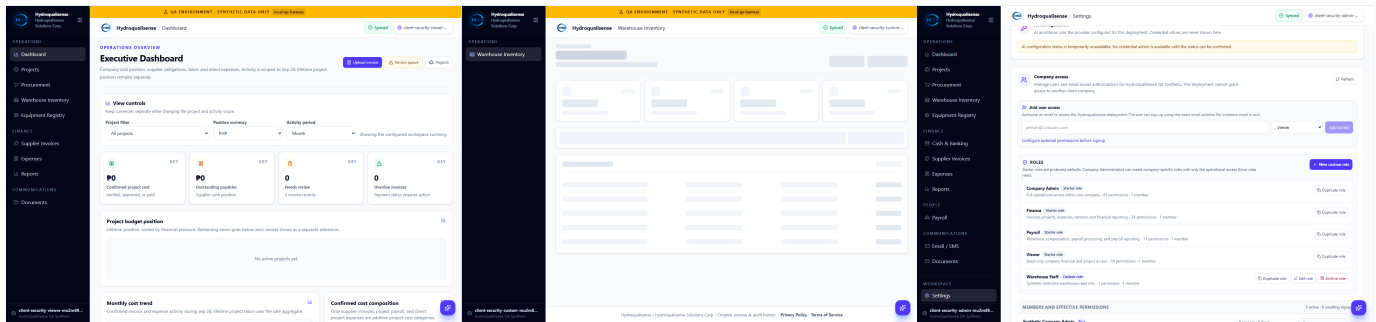
The captures below use authenticated synthetic QA accounts against the exact tested branch and desktop size. They document the local QA behavior of this handoff; hosted deployment certification and production verification remain separate release checks.



Company Admin navigation from synthetic QA

Finance navigation from synthetic QA

Payroll navigation from synthetic QA



Viewer navigation from synthetic QA

Custom restricted role navigation from synthetic QA

Company Access and custom-role editor from synthetic QA

The menu follows the user's permissions, but hiding a menu is not the security control by itself. Protected routes and important operations are checked again by the application, server, and database.

4. How your data stays isolated

Each client deployment has its own application, database, sign-in users, private file storage, settings, and connected provider configuration. The application does not provide a switch for unrelated client companies inside one deployment.

Access is checked in more than one place:

- the workspace shows only areas that match the user's effective access;
- protected requests are checked again before work is performed;
- company boundaries are checked before company records are returned or changed;
- private files use company-specific storage boundaries;
- important access and business changes retain an audit trail where the workflow supports it.

Payroll project references are limited to the small amount of project identity needed for payroll context. They do not give a Payroll user the general Projects workspace.

Financial, document, payroll, and provider records keep their own source and history rules. A summary or shortcut does not replace the record that owns the underlying truth.

5. Choose your support and custody model

Hydroqualisense supports two legitimate operating models. Your choice is an operational handoff decision, not an application setting.

Option A - Managed Support Access

You keep ownership of production and give a named Hydroqualisense support account the minimum access reasonably needed for approved maintenance and troubleshooting, under an NDA or equivalent confidentiality obligation.

Use individual accounts, least privilege, MFA where the provider supports it, client-controlled granting and revocation, and available access logging. Access is not an invitation to browse confidential records routinely.

Pros: faster troubleshooting; easier approved maintenance, migration, or configuration work; direct verification of environment-specific problems; less technical work for your team; faster recovery from production-only issues.

Cons: the support operator retains some production access; the arrangement requires trust, confidentiality, account controls, and monitoring; data may be reachable within the permissions granted; access must be reviewed and removed when no longer needed.

Option B - Independent Client Control

Your team owns and controls production Supabase, Render, Auth, Storage, Google, AI, and SMS/provider accounts. Standing Hydroqualisense developer/operator production access is removed after handoff.

Hydroqualisense can still develop and test source-code fixes and deliver reviewed software updates. Direct production inspection or production changes require your cooperation or temporary access.

Pros: no standing developer data access; the strongest separation between client and developer accounts; your team completely controls who can access production; access can be granted only when you decide it is needed.

Cons: some production issues take longer to diagnose; your team may perform operational steps; some production migrations or configuration changes may require client execution or temporary access; environment-specific issues may wait for evidence or approved temporary access.

Both models can use temporary incident access: **client approval -> named limited account/access -> specific incident -> activity recorded where practical -> access removed**. Password sharing is not required.

6. Integrations and secrets

Email

Gmail authorization and provider credentials are handled through the server. The application keeps human review before a consequential outbound send and retains delivery history for supported document workflows.

AI and private files

AI credentials and private file access are handled on the server. A missing provider, file-storage prerequisite, or document converter is shown as unavailable rather than being presented as ready.

SMS

The approved choices are:

- **Company SIM Gateway** - the recommended option when the company uses its own SIM;
- **PhilSMS** - an optional hosted Philippine fallback.

For this handoff, SMS remains **not configured and unverified**. No message was sent as part of the security evidence work.

Secrets should remain in the client-approved provider or deployment secret store. They should not be placed in browser storage, screenshots, support tickets, or shared documents.

7. Shared responsibility and verification

Source-code maintenance does not require standing production database access. Normal support can reproduce a problem with QA and synthetic data, develop and test a fix, and deliver a reviewed software release.

Direct production diagnosis, some production migration or configuration work, and environment-specific verification may require client cooperation or temporary access. This is different from developing and testing a source-code fix.

Before handoff, the client and authorized operator should record:

- the deployment and release being handed over;
- the client-controlled Supabase, Render, Auth, Storage, Google, AI, and SMS/provider accounts;
- the selected support/custody model;
- who can administer Company Admin access;
- whether standing developer access has been removed or deliberately retained under the managed-support model;
- how an exceptional incident grant will be approved, recorded, and removed.

This overview makes no compliance certification claim. It does not promise zero risk, a recovery time, a retention period, geographic residency, or provider delivery. The operational checklist and supporting evidence record are maintained separately so each client deployment can be re-verified without exposing confidential records.